



REPUBLIC OF ZAMBIA

In reply please quote:

No.:

OAG/101/2/97

OFFICE OF THE AUDITOR-GENERAL

P.O. BOX 50071
RIDGEWAY
LUSAKA, ZAMBIA

8th May 2026

The Chief Executive Officer
National Road Fund Agency
P. O. Box 50695
LUSAKA



RE: INTERIM MANAGEMENT LETTER ON THE AUDIT OF FINANCIAL STATEMENTS HEAD 37 – MINISTRY OF FINANCE AND NATIONAL PLANNING, ROAD TOLLS AT THE NATIONAL ROAD FUND AGENCY FOR THE FINANCIAL YEAR ENDED 31ST DECEMBER 2025

1. Introduction

The Road Toll Collections which forms part of the Financial Statements for Head 37 – Ministry of Finance and National Planning, National Road Fund Agency (NRFA) is subject to audit by the Auditor General in accordance with the provisions of Article 250 of the Constitution of Zambia (Amendment) Act No. 2 of 2016, Public Audit Act No. 29 of 2016 and Public Finance Management Act No. 1 of 2018.

The audit of the Road Toll collection for the period January to December 2025 was completed and the purpose of this letter is to bring to your attention the findings that were observed during the audit.

2. Objectives of the Audit

The objectives of the audit were to ascertain:

- a. Whether Road Tolls collected were properly accounted for and timely banked,

- b. Whether there was an efficient system of monitoring the transfer and reconciliation of revenues from different revenue collection points into the transit accounts and ultimately to Control 99,
- c. Whether the National Road Fund Agency (NRFA) was proactive in countering and detecting potential fraud and malpractices,
- d. Whether there was compliance with relevant laws, rules and regulations in revenue collection, and
- e. To express an opinion on the financial statements:

3. Audit Scope and Limitation

The audit covered the period from 1st January 2025 to 31st December 2025 and was carried out at the National Road Fund Agency Headquarters and verifications were also conducted in selected stations in the districts.

4. Audit Methodology and Strategy

The audit was conducted in accordance with the International Organisation of Supreme Audit Institutions (INTOSAI) Standards of Supreme Audit Institutions (ISSAIs). These standards require that the audit is planned and performed so as to obtain reasonable assurance that, in all material respects, fair presentation is achieved in the annual financial statements.

The audit also included an examination, on a test basis, of evidence supporting compliance in all material respects with the relevant laws and regulations which came to our attention and are applicable to financial matters.

5. Responsibility of Management and Auditor General

Management is responsible for the maintenance of effective internal controls designed to provide reasonable assurance regarding the achievement of strategic objectives, reliability and integrity of financial and operational information, effectiveness and efficiency of operations, safeguarding of assets, and compliance with applicable laws, regulations and contracts.

The responsibility of the Auditor General is to audit the Accounts and express an independent opinion on Financial Statements.

6. Background

a. Establishment

The National Road Fund Agency (NRFA) is a Statutory Body under the Ministry of Finance and National Planning (MoFNP) established by the National Road Fund Act No.13 of 2002 after the disbandment of the National Roads Board (NRB) in May 2000. It provides fiduciary oversight over all Road Sector Finances in the Country.

On 1st November 2013 through provisions of the Tolls Act No. 14 of 2011, the National Road Fund Agency launched the National Road Tolling program by commissioning collection of Road Tolls at gazetted weighbridges from all heavy good vehicles.

In September 2015 the Road Development Agency appointed the National Road Fund Agency as a lead Toll Agent to operate all Toll collection points in the country. Furthermore, in March 2024, the Road Development Agency (RDA) appointed the Zambia Revenue Authority (ZRA) as the toll collector for all ports of entry.

During the period under review, toll fees and weighbridge fines were collected from a total of thirty-eight (38) stations. Of these, twenty-four (24) were managed by the National Road Fund Agency (NRFA) and eleven (11) by the Zambia Revenue Authority (ZRA).

Pursuant to provision Part II Section 6(1) of the Tolls Act No 14 of 2011, the mandate of the National Road Fund Agency (NRFA) is to mobilise, administer and manage all financial resources in the road sector. Its principal functions are to:

- i) Administer and manage the National Road Fund (NRF),
- ii) Prepare and publish audited annual accounts of the NRF,
- iii) Recommend to the Minister of Finance and National Planning fuel levy and other road user charges and tariffs,
- iv) Allocate resources for the construction, maintenance and rehabilitation of road based on a percentage of the annual work plan of the Road Development Agency,
- v) Allocate resources for road transport, traffic safety management based on a percentage of the annual work plan of the Road Transport and Safety Agency and

vi) Recommend funding for the development of new roads in consultation with RDA.

b. Board of Directors

According to the National Road Fund Act No. 13 of 2002, the NRFA is required to be overseen by a Board of Directors consisting of thirteen (13) nonexecutive members. The members of the Board are appointed by the Minister responsible for a term of three (3) years which is renewable.

c. Management

The day-to-day operations of the NRFA are a responsibility of the Executive Director appointed by the Board of Directors and is supported by five (5) directors in charge of Fund Management, Monitoring and Evaluation, Corporate Support, Internal Audit and Road Tolling Departments.

The directors are appointed on renewable contracts of three (3) years.

d. Revenue Collection Mandate

The National Road Fund Agency collects revenue in form weighbridge charges and Toll fees, collected from overloaded heavy good vehicles, inland and foreign tolls. The revenue collected by the Agency from inland toll stations is deposited into the revenue transit account which later transmits funds to Control 99 maintained at Bank of Zambia.

e. Management Information Systems

During the period under review, the following Toll Management Information Systems were used in the collection of toll fees and weighbridge fines.

- i. **NECOR Toll Management System** – This is the main toll collection System which is operated at all toll stations.
- ii. **e-Toll Management Information System** - This is a centralised application that is used by road users to make cashless payments at various toll stations using the Electronic Toll Cards.
- iii. **Weighbridge Information System (WIS)** – WIS is a weighbridge information system that was used to operate multi-deck bridge scales at Kapiri Mposhi, Katete, Chongwe, Mumbwa and Kafue weighbridges for registration and weighing of trucks, certification and receipting.

- iv. **Axle Loop** - The Axle loop Weighbridge Management System is a single deck weighbridge system that was operated at Mpika, Kafulafuta, Livingstone, Kafue Kazungula weighbridges for registration, weighing and certification of trucks.

7. Audit Findings

An examination of accounting and other records maintained at the National Road Fund Agency Headquarters, selected toll stations, boarder posts and weighbridges across the country, revealed the following:

a. Budget against Actual Collections

In the Estimates of Revenue and Expenditure for the financial year ended 31st December 2025 a total revenue provision of K1,422,903,515 was made against which amounts totaling K1,828,573,475 were collected resulting in an over collection of K405,669,941. **See table 1 below**

Table 1: Budget against Actual Collections

S/n	Station	Budgeted Amounts (K)	Actual Collections (K)	Variance (K)
1	Shimabala	208,183,425.05	230,803,407.00	22,619,981.95
2	Chilonga	90,064,229.89	118,170,230.00	28,106,000.11
3	Mumbwa	20,884,734.48	26,437,306.00	5,552,571.52
4	Kateshi	20,309,070.72	25,747,490.46	5,438,419.74
5	Kalense	17,926,754.60	24,679,864.00	6,753,109.40
6	Chembe	23,964,929.37	34,897,053.71	10,932,124.34
7	Chongwe	62,890,492.12	67,933,222.47	5,042,730.35
8	Kakonde	14,728,214.08	22,020,360.25	7,292,146.17
9	Micheal C Sata	240,721,248.46	329,214,557.14	88,493,308.68
10	Humphrey Mulemba	52,516,364.14	59,810,569.00	7,294,204.86
11	Tapo	2,345,741.33	2,160,565.00	(185,176.33)
12	Mweeke	12,433,117.25	13,190,692.00	757,574.75
13	Lui	8,460,877.77	9,204,553.90	743,676.13
14	Daniel Mukombwe	74,011,655.34	90,594,542.55	16,582,887.21
15	Enock Kavindele	57,575,878.49	68,810,868.38	11,234,989.89
16	Mpongwe	10,112,499.35	15,233,752.00	5,121,252.65
17	Ntoposhi	14,811,008.02	23,149,432.46	8,338,424.44
18	Wilson M Chakulya	131,571,963.01	140,872,792.20	9,300,829.19
19	Mibenge	9,334,504.53	12,150,693.00	2,816,188.47
20	Reuben C Kamanga	21,381,006.50	22,130,655.57	749,649.07
21	Alexander Grey Zulu	30,030,473.08	35,960,547.46	5,930,074.38
22	Kebby Musokotwane	63,919,279.95	81,154,097.98	17,234,818.03
23	George kunda	105,712,704.05	136,233,718.00	30,521,013.95
24	Sabina	129,013,343.96	148,902,937.7	19,889,593.74
25	Simon M Kapwepwe	0.00	38,296,202.58	38,296,202.58
26	Donald Siwale	0	38,678,460.53	38,678,460.53
27	Kafulafuta Toll Ext	0	3,096,875.68	3,096,875.68
28	Kapiri Mposhi Toll	0	9,038,010.00	9,038,010.00
	Total	1,422,903,515.51	1,828,573,457.02	405,669,941.51
	Weighbridge	57,200,000.00	137,753,295.00	80,553,295.00
	Ports of Entry(ZR)	1,886,044,484.50	4,056,908,030.07	2,170,863,545.57
	Grand Total	3,366,148,000.01	6,023,234,782.09	2,657,086,782.08

Although the National Road Fund Agency (NRFA) reported an overall over-collection of K405,669,941.51 on tolls fees during the period under review, it was noted that Tapo Toll Station did not meet its projected revenue target, resulting in an under-collection of K185,176.33. Management did not provide an explanation for the failure to achieve the set revenue target.

Furthermore, it was observed that the Agency did not provide projected revenue targets for four (4) toll stations, which collectively recorded actual collections amounting to K89,109,548.79.

Consequently, it was not possible to assess the performance of these toll stations against their respective targets. See table 3 below

Table 3: An Extract from Budget Vs Actual Collection Table

No	Toll Station	Budgeted Amount(K)	Actual Collection(K)	Variance(K)	Table 1 Refers
1	Simon M Kapwepwe	-	38,296,202.58	38,296,202.58	No. 25
2	Donald Siwale	-	38,678,460.53	38,678,460.53	No. 26
3	Kafulafuta Toll Extensions	-	3,096,875.68	3,096,875.68	No. 27
4	Kapiri Mposhi Toll Extensions	-	9,038,010.00	9,038,010.00	No. 28
Total		-	89,109,548.79	89,109,548.79	

Risk

Toll Stations may be underperforming.

Recommendation

Management should ensure that revenue estimates are set in all the toll stations for performance evaluation purposes.

Management Response

b. Discrepancy in Reported Amounts – Tolling

i. Discrepancy Between Station Returns and Returns Submitted to Ministry of Finance

A comparison of the returns obtained from National Road Fund Agency Head Quarters which were submitted to the Ministry of Finance and the returns obtained from ten (10) Toll stations revealed that, the returns provided at NRFA HQ had a total reported figure amounting to K762,412,924 while the returns obtained from ten (10) Toll Station had a total of K762,705,747 resulting in a variance of K292,823. Consequently, the report figure submitted to the Ministry of finance could have been misstated. See Table 4 below.

Table 4: Comparison of HQ Returns and Station Return.

No.	Toll Station	HQ Returns(K)	Station Returns (K)	Variance(K)	Refer To
1	Wilson Mofya Chakulya	140,872,792.20	140,832,456.20	40,336.00	Sch 1a
2	Enock Kavindele	68,810,868.38	68,815,208.25	- 4,339.87	Sch 1b
3	Sabina	148,902,937.70	148,897,114.70	5,823.00	Sch 1c
4	George Kunda	136,233,718.00	136,577,008.00	- 343,290.00	Sch 1d
5	Chilonga	118,170,230.00	118,161,750.00	8,480.00	Sch 1e
6	Kateshi	25,747,490.46	25,747,198.96	291.50	Sch 1f
7	Kalense	24,679,864.00	24,677,664.00	2,200.00	Sch 1g
8	Kakonde	22,020,360.25	21,975,494.00	44,866.25	Sch 1h
9	Donal Siwale Station	38,678,460.53	38,658,874.00	19,586.53	Sch 1i
10	Simon Mwansa Kapwepwe	38,296,202.58	38,362,979.00	- 66,776.42	Sch 1j
11	Mpika Weighbridge	4,908,570.60	4,905,665.54	2,905.06	Sch 1k
12	Kapiri Weighbridge	10,640,159.31	10,987,163.62	- 347,004.31	Sch 1l
Total		777,961,654.01	778,598,576.27	- 292,823.01	

Risk

Misstatements of revenue reports.

Recommendation

Management should ensure that reconciliations of the annual returns at NRFA HQ and the toll stations are done before Submission to the Ministry of Finance.

Management Response

ii. Unreconciled Revenue Collections - Transit Accounts

Regulation 8 of statutory instrument No. 97 of 2020 states that an accounting officer shall; Undertake a reconciliation of accounts held under that accounting officer's charge at least once in a month. Prepare and dispatch in a timely manner financial statements and returns to a relevant authority.

A comparison between the revenue collections reported in the Returns and the amounts reflected in the transit accounts for nine (9) sampled toll stations revealed discrepancies. While K861,187,539.37 was reported in the revenue returns, only K533,516,003.09 was

recorded in the transit accounts, resulting in an unreconciled variance of K327,671,536.28.

See to Table 5 below.

Table 5: Total Revenue collected through the Transit Accounts

No	Name of Station	Annual Return- 2025(K)	Total Transit Accounts Collections(K)	Difference(K)	Refer to
1	Micheal Chilufya Sata	329,214,557.14	244,125,248.94	85,089,308.20	Sch 2a
2	Mpongwe	15,233,752.00	8,843,654.00	6,390,098.00	Sch 2b
3	Shimabala	230,803,407.00	121,086,451.00	109,716,956.00	Sch 2c
4	Mumbwa	23,884,243.00	16,918,573.00	6,965,670.00	Sch 2d
5	Nalumino Mundia	13,189,557.00	5,639,338.00	7,550,219.00	Sch 2e
6	Lui	9,204,553.00	3,498,117.90	5,706,435.10	Sch 2f
7	Kebby Musokotwane	81,135,308.72	45,841,646.21	35,293,662.51	Sch 2g
8	Danniel Munkombwe	90,592,771.54	42,765,671.64	47,827,099.90	Sch 2h
9	Chongwe	67,929,389.97	44,797,302.40	23,132,087.57	Sch 2i
10	Kapiri Weighbridge	10,987,163.62	7,589,687.02	3,397,476.60	Sch 2j
11	Livingstone Weighbridge	1,465,111.87	1,447,787.37	17,324.50	Sch 2k
12	Kafue Weighbridge	10,378,874.79	10,352,601.49	26,273.30	Sch 2l
Total		861,187,539.37	533,516,003.09	327,671,536.28	

As of April 2026, the Agency had not provided the reconciled position.

Risk

Overstatement of revenue.

Recommendation

Management should ensure that bank reconciliations are performed by the toll stations before submitting the returns.

Management Response

iii. Delayed Transfer of Revenue to Control 99 (Weighbridge fees)

Section 28(6) of the Public Finance Management Act No.1 of 2018 stipulates that an appointed agent that fails to transmit funds to the Consolidated Fund in accordance with subsection (1) commits an offence and is liable, on conviction, to a penalty at the prevailing

interbank lending rate applicable on the untransmitted amount for each day the amount remains unremitted. Further, the Service Level Agreement (SLA) between the Government and commercial banks stipulates that funds in the revenue transit account held at commercial banks should be transferred to Control 99 on Tuesdays, Fridays and the last working day of each month and that any delays should attract a penalty of 10% simple interest, calculated on the overnight balance remaining on the account.

A scrutiny of the Zanaco bank statements for Weighbridge charges revealed that there were delays ranging from 3 to 5 days in remittances of revenues in amounts totalling K36,167,561 by Zanaco bank to Control 99 at the Bank of Zambia. **Schedule 17**

Risk

The Government may be delayed access to the funds.

Recommendation

Management should ensure that all the terms of the Service Level Agreement are enforced and collect all the penalties relating to the delays by the commercial banks to transfer the funds to control 99.

Management Response

iv. Partial Sweepouts to the Consolidated Funds Control 99 (Weighbridge fees)

The Service Level Agreements (SLAs) between the Government and the commercial banks stipulates that funds in the revenue transit account held at commercial banks should be transferred to Control 99 on Tuesdays, Fridays and the last working day of each month and that any delays should attract a penalty of 10% simple interest, calculated on the overnight balance remaining on the account.

A scrutiny of the Zanaco bank statements for Weighbridge Charges revealed that on several occasions, the banks were not fully sweeping accrued amounts on the transit accounts but left significant balances of revenues in amounts totalling K16,685,852 as at 31st December 2025. **Schedule 18**

Risk

Government may be denied access to the funds.

Recommendation

Management should ensure that there is adherence to the instructions contained in the Service Level Agreements with the commercial banks.

Management Response

c. Contract for Provision of Banking Services

During the period under review, the National Road Fund Agency (NRFA) entered into three (3) contracts with three (3) banks namely; Stanbic Bank Zambia Limited, Zambia National Commercial Bank and Atlas Mara for the provision of banking services for a period of twelve (12) months.

The scope of services included provision of Teller Implant, Cash in Transit and Banking Services (cash deposit into designated bank accounts) in respect of collected tolls at specified Toll Stations on daily basis. The service provider would bear all the costs incurred in connection with the performance of the duties and obligations under the contracts and comply with Service Level Agreement as entered into between GRZ and Banking Financial Institutions.

The following were however observed;

i. Failure to Transfer Funds to Bank of Zambia Control Account

Section 10 of the Public Finance Management Act No. 1 of 2018 states that, *a controlling officer designated by the Secretary to the Treasury under Section 7, shall be responsible and accountable for the proper financial management and expenditure of public monies appropriated to public bodies in respect of all public monies collected, received or disbursed and in respect of public stores or assets received, held or disposed of by or on behalf of the ministry or department or service for which such head is provided.*

Clause 2.2.9 of the Service Level Agreement (SLA) between the Government of the Republic of Zambia and First National Bank (FNB) gives instructions to the bank, to sweep all funds, clearing on the Revenue Transit Account to the designated BOZ accounts, on Tuesdays based on Monday's cleared balances, on Fridays based on Thursday's cleared balances, and on the last working day of every month based on the previous working days cleared balance if the last working days falls on Tuesday or Friday, the sweeping should proceed normally.

An examination of the bank statements revealed that, revenue in amounts totalling K154,208,858.00 was collected through two (02) accounts held with FNB between September 2025 and December 2025 had not been swept to Bank of Zambia as of April 2026. See Table 6 below

Table 6: Funds Not Swept to Bank of Zambia Control Account

No.	Bank Name	Account No.	Collection Period	Total revenue Collected(K)	Refer to
1	FNB	63172749253	02/09/2025 to 31/12/2025	151,801,155.39	Sch 3a
2	FNB	63172348344	03/09/2025 to 29/12/2025	2,407,703.00	Sch 3b
Total				154,208,858.39	

Furthermore, no evidence was provided to indicate that the Agency formally notified the Ministry of Finance and National Planning of the bank's failure to comply with its contractual obligations.

Risk

The Government may be deprived from accessing funds to finance its programmes.

Recommendation

Management should ensure that movements of funds in the transit accounts are being monitored regularly and that the contract terms as contained in the Service Level Agreements are followed.

Management Response

Unauthorised Debit Entries on the Bank Statements

Clause 2.2.8 of the Service Level Agreements states that, the bank shall not allow debit transactions on the Revenue Transit Accounts apart from single sweeps to BOZ. Further Clause 2.1.14.1 of the Service Level Agreements between the Government of the Republic of Zambia and the Commercial Banks state that, the Bank shall operate a GRZ account to prevent the incidence of errors requiring correction on the account statement. Errors on account statements shall be corrected within five (5) working days of the bank being notified of the error by the appropriate government institution.

In the event that an error is made in a transaction posted to any GRZ Account, the bank shall notify the Office of the Accountant General or the appropriate government institution in writing and provide details of error which shall include original erroneous transaction and the transaction which were posted to correct the error, and preventative measures the bank will implement to prevent the reoccurrence of such an error in future. Such notification will be made within five (5) working days of the error being identified.

A review of bank statements for the transit accounts revealed seventy-two (72) debit transactions (50 - Stanbic Bank and 22 - Zanaco Bank) in amounting totalling K6,040,919.50 (K5,203,351.00 for Stanbic Bank and K837,568.50 for Zanaco Bank).

As of April 2026, the National Road Fund Agency (NRFA) had not provided supporting documentation for these debit entries. Additionally, no evidence was availed to indicate that the Ministry of Finance and National Planning had been notified of these transactions.. See **Table 7 below**

Table 7: Debit Entries on Transit Accounts

No.	No. Of Trans	Bank Name	Account No.	Period	Unathourised Debit Entries	Refer to
1	50	Stanbic	9130001143658	01/01/2025 to 31/12/2025	5,203,351.00	Sch 4a
2	22	Zanaco	2008220300161	01/01/2025 to 31/12/2025	837,568.50	Sch 4b
					6,040,919.50	

Risk

Fraudulent transactions may be debited to the transit accounts and may not be detected.

Recommendation

Management should ensure that debit entries are explained.

Management Response

ii. Delayed banking

Section 128 (1) of Public Finance Management (General) Regulations requires that an office holder who receives or collects revenue shall deposit the revenue not later than the next business day following the day of receipt of revenue.

Contrary to the Regulation, there were delays of periods ranging from 2 to 88 days in banking revenue into the transit account held with FNB bank for toll fees in amounts totalling K39,570,718 collected during the period under review. It was further observed that accrued interest in amounts totalling K20,630 had not been claimed from the commercial banks as of April 2026. **Schedule 5**

Risk

The Government may be delayed access to the funds.

Recommendation

Management should ensure that revenue is deposited not later than the next business day following the day of receipt of revenue.

Management Response

d. Unaccounted for Revenue

Section 7 of the Public Finance Management Act No. 1 Of 2018 states that, A controlling officer shall collect, account and promptly remit to the Treasury all monies due to the Government under the responsibility of the controlling officer

A review of the Cash Book and Bank Deposit Slips at Shimabala Toll Station in respect of prepayments revealed that revenue amounting to K351,190.00 was collected between 1st May 2025 and 31st May 2025 for toll fee prepayments. However, the entire amount collected

could not be traced to the corresponding bank statements under Station Bank Code SIMT2001 thus unaccounted for. (Schedule 6a & 6b)

As of April 2026, the Agency had not provided any supporting documentation.

Risk

Loss of revenue

Recommendation

Management should ensure that the collected prepayments amounts are accounted for and also ensure that regularly bank reconciliations are performed.

Management Response

e. Failure to file bank deposit slips in an orderly manner to support bank reconciliation

Regulation 8 (f) of Statutory Instrument No. 97 of 2020 stipulates that, an accounting officer shall undertake a reconciliation of accounts held under that accounting officer's charge at least once in a month.

During the period under review, it was observed that deposit slips for various transit accounts relating to Chongwe, Daniel Munkombwe, Kebby Musokotwane, Lui, and Nalumino Mundia Toll Stations were filed together in a single box file. As a result, it was difficult to isolate and retrieve specific deposit slips for individual stations, thereby hindering effective verification during bank reconciliation processes

Risk

Errors and fraudulent transactions may not be detected.

Recommendation

Management should ensure that all the deposit slips from various accounts are isolated for easy retrieval during bank reconciliations.

Management Response

f. Inconsistencies in Toll Charges

According to the revised Road Toll Fee Chart effective 1st January 2025, the applicable fees for the different vehicle categories of vehicles are as follows:

Table 8: Applicable Fee Chart

No.	Vehicle Category	Applicable Fee
1	Class A	20
2	Class B	40
3	Class C	300
4	Class D	460
5	Class E	800

A review of the Necor and E-Tolling Systems revealed inconsistencies in toll charges in that

A review of the Necor and E-Tolling Systems revealed inconsistencies in toll charges in that 4,062 motor vehicles with the same registration numbers were involved in 9,809 transactions and charged different toll fees in circumstances that were unclear from seventeen (17) toll stations. Consequently, the Government suffered revenue loss in amounts totalling K 280,350 and over charge of K2,780. **Refer to Table 9 below**

Table 9: Inconsistencies in Toll Charges

No	Name of Toll Station	No. of Motor Vehicles	No. Of Transactions	Revenue Loss K	Over Charge K	Refer to
1	Shimabala	3,176	6,557	194,860		7(a)
2	Nalumino Mundia	16	389	4,960		7(b)
3	Lui	3	6	70		7(c)
4	Kebby Musokotwane	246	1,560	43,980		7(d)
5	Danniel Munkombwe	36	210	5,920		7(e)
6	Chongwe	55	27	6,040		7(f)
7	Enock Kavindele	40	80		900	7(g)
8	Kateshi	71	142	1,710	1,680	7(h)
9	Micheal Chilufya Sata	39	78	830		7(i)
10	Sabina	28	56	880	200	7(j)
11	Gorge Kunda	105	210	2,990		7(k)
12	Chilonga	105	210	4,790		7(l)
13	Donald Siwale	45	90	2,720		7(m)
14	Simon Mwansa Kapwepwe	49	98	7,620		7(n)
15	Wilson Mofya	48	96	3,080		7(o)
Total		4,062	9,809	280,450	2,780	

Risk

loss of funds

Recommendation

Management should ensure that there are adequate internal controls to prevent inconsistencies in charging toll fees to vehicles with the same registration numbers and investigate all the cases of inconsistencies for disciplinary action.

Management Response

g. Management of Local User Discounts (LUDs)

Statutory Instrument No. 85 of 2016 stipulates that a local user is a road user driving a Zambian registered vehicle domiciled within a ten-kilometer (10km) radius of an inland toll point, excluding a point of entry for a specified period.

Further, Section 3.4 of the Road Tolling Procedure Manual stipulates that a motorist applying for a Local User Discount (LUDs) shall apply on form LUD RT006 accompanied by the following documentation.

- a) Proof of vehicle ownership
- b) Copy of Identity card
- c) Proof of Residence (within 10km radius)

i. Irregular award of Local User Discounts (LUDs) - Micheal Chilufya Sata

A scrutiny of the toll collection report revealed that 105 motor vehicles were awarded local user discounts at Michael Chilufya Sata Toll Station in the year under review. However, an examination of the identity cards and the proof of residence revealed that 15 applicants were awarded Local User Discounts even though their proof of residence (within 10km radius) could not be matched to the copy of identity card for the applicants. Consequently, the Government lost revenue in amounts totalling K14,080 in the year under review. **Schedule**

8a

Risk

Loss of revenue through Local User Discounts.

Recommendation

Management should ensure that only the applicants with valid documentation are awarded LUDs.

Management Response

ii. Irregular award of LUDs - Kebby Musokotwane and Chongwe Toll Station

A review of Road Toll transactions and Local User Discount (LUD) Registers during the period under review revealed that six (6) motor vehicles at Kebby Musokotwane Toll Station and ninety-one (91) motor vehicles at Chongwe Toll Station, which were granted Local User Discounts, were not recorded in the respective LUD Registers. Furthermore, no supporting documentation was availed for audit to justify the granting of these discounts.

Consequently, there was a loss of revenue at Kebby Musokotwane and Chongwe toll stations in amounts totalling to K20,490.00 and K345,230.00 respectively. **Schedule 8b and 8c.**

Risk

Loss of funds

Recommendation

Management should ensure that LUD register is updated annually and only motor vehicles contained on the register should be awarded the discounts when passing through the toll gates.

Management Response

h. Award of Frequent User Discounts (FUDs) to Foreign Registered Vehicles

The Ministerial Statement on the introduction of Road User Payments of Frequent User Discounts (FUDs) in Public Road Tolling which stipulates that a frequent user is a vehicle falling within category A and B of the toll tariff structure under the Third Schedule (Regulation 5) of Statutory Instrument No. 85 of 2016.

The discount rate shall be 25% of the nominal rates of K20 and K40 respectively. For a vehicle to be eligible for FUD, it shall pass through a toll station at least ten (10) consecutive times within a thirty (30) day period, thereafter, such a vehicle shall qualify to pay at FUD rates for a closed period of another thirty (30) days.

Further, part 2 (b) of the Toll Amendment Regulation of 2020, defines a frequent user as a Zambian registered vehicle that uses a tolled road for a specified period.

A scrutiny of the toll collection report revealed that one (1) motor vehicle with foreign registration No. 7960AB14 was awarded frequent user discount at Michael Chilufya Sata Toll Station on three (3) occasions between 15th January and 31st January 2025. In this regard, NRFA did not comply with the regulation that restricts the award of frequent user discounts to Zambian registered vehicles. Consequently, there was a loss of K45.**Schedule**
9

Risk

Loss of funds

Recommendation

Management should ensure that they are complying with the laws and guidelines that govern the FUD.

Management Response

i. Failure to Provide Information – High Traffic Vehicles on FUD

Regulation 4 (f) of Statutory Instrument No. 97 of 2020 states that, Subject to the direction of a controlling body, the functions of an accounting authority are to submit reports, returns, notices and other information that may be required by the Act or any other written law of a state-owned enterprise or local authority to the National Assembly, the Auditor General and the Treasury.

According to Statutory Instrument No. 85 of 2016, the introduction of Road User Payments of Frequent User Discounts (FUDs) in Public Road Tolling which stipulates that a frequent

user is a vehicle falling within category A and B of the toll tariff structure under the Third Schedule (Regulation 5) of the

The discount rate shall be 25% of the nominal rates of K20 and K40, respectively. For a vehicle to be eligible for FUD, it shall pass through a toll station at least ten (10) consecutive times within a thirty (30) day period; thereafter, such a vehicle shall qualify to pay at FUD rates for a closed period of another thirty (30) days.

A review of the cashbook transactions at Michael Chilufya Sata toll station revealed that three (3) vehicles which passed through the toll plaza 560 times in 20 days between 2nd September and 28th September 2025. However, the toll station did not provide the requested information involving the images of the three (3) vehicles in question for audit scrutiny. In this regard, failure by the system to capture vehicles may result in failing to monitor and reconcile inconsistencies in vehicle charges. **Schedule 10**

Risk

It may be difficult to conclude the matter during the audit.

Recommendation

Management should ensure that all information requested by the auditors is given on time.

Management Response

j. Undercharging of Toll Fees for Abnormal Vehicles

According to the revised Road Toll Fee Chart effective 1st January 2025, the applicable fees for the different vehicle categories of motor vehicles are as follows:

Table 10: Effective Fee Chart During the Period

No.	Vehicle Category	Vehicle Type	Applicable Fee
1	Class A	Small Vehicle	20
2	Class B	Minibus	40
3	Class C	Bus/Light Truck	50
4	Class D	Semi Truck	250
5	Class E	Abnormal Load	800

A review of the Main System and the E Tolling System revealed significant inconsistencies in toll charges. Specifically, abnormal load motor vehicles with identical registration numbers were charged different toll fees at Chongwe, Kebby Musokotwane, Nalumino Mundia, Mumbwa and Shimabala Toll Stations, involving 13,373 transactions, resulting in a revenue loss of K 7,095,540.

See Table 11 below

Table 11: Toll Stations that Undercharged Fees for Abnormal Vehicles

No	Station Name	No. Transactions	Revenue Loss(K)	Refer to
1	Chongwe	205	119,770.00	Sch 11a
2	Kebby Musokotwane	3,428	1,888,960.00	Sch 11b
3	Nalumino Mundia	1,850	1,017,500.00	Sch 11c
4	Mumbwa	6,273	3,460,840.00	Sch 11d
5	Shimabala	1,617	608,470.00	Sch 11e
Total		13,373	7,095,540.00	

Risk

Loss of funds

Recommendation

Management should ensure that internal controls that prevent inconsistencies are enhanced and investigations should be done for disciplinary action.

Management Response

k. Non-Functional Boom Barriers

NRFA Tolling System Procedure Manual, bullet No. 3 describes the control that is in place to prevent passage of motor vehicles by the Boom barriers installed at the toll gates. Boom barriers automatically open once a transaction has been completed by a toll collector. (automated control)

However, during the physical inspection conducted between 5th March and 27th March 2026 at Shimabala, Chongwe, Kebby Musokotwane, Nalumino Mundia, Micheal Chilufya Stata, Wilson Mofya, Enock Kabvindele, George Kunda and Mumbwa toll stations, it was observed that the toll stations had non-functional boom barriers. A review of the job cards and an inquiry from Toll Collectors revealed that all the nine (9) stations were operating without the Boom barriers for the

year ended 31st December 2025. In addition, there was no documentary evidence provided for audit that management attempted to repair the Boom barriers during the year under review. Consequently, the stations lost one of the controls that would prevent abscondments of motor vehicles.

Risk

There may be an increase in the number of abscondments of motor vehicles.

Recommendation

Management should ensure that high quality Boom barriers are installed, and frequent maintenance and repairs are planned for and conducted in all the toll stations annually.

Management Response

I. Unpaid for Abscondments

Section 9. (1) of the Tolls Act No. 14 of 2011 states that a driver of a vehicle passing through a toll point shall, at the time of passing through the toll point, pay the toll in respect of that vehicle to the toll collector. In addition, section 22 of the same Act states that a person who (a) fraudulently or forcibly drives a vehicle through a toll point or without paying the toll commits an offence and is liable, upon conviction, to a fine not exceeding three hundred thousand penalty units or to imprisonment for a period not exceeding three years, or to both.

A review of abscondment records obtained from NRFA Headquarters revealed that twenty-two (22) toll stations failed to collect revenue amounting to K422,790.00, arising from abscondments involving 171 motor vehicles during the period under review. As at 31st December 2025, the full amount remained outstanding. **Schedule 12**

Risk

Loss of funds.

Recommendation

Management should ensure that all the cases of abscondments are followed to the later and ensure that the related fines are collected to deter potential offenders in the future.

Management Response

m. Weighbridge Fees

An examination of accounting records and other relevant documents maintained at Mpika, Kapiri Mposhi, Livingstone, and Kafue Weighbridge stations for the financial year ended 31st December 2025 revealed the following:

i. Overloaded Vehicles Without Payment

Section 35(2) of the Public Roads (Maximum Weight of Vehicles) Regulations of 2007 states that “an overload is determined to have occurred if the weights determined by weighing are higher than the authorised limits.” In addition, Section 35(3) provides that “for the purpose of axles or combinations of the distribution of the load on a vehicle, an axle or combination of axles shall be deemed overloaded if the load exceeds the authorised limit after the addition of five per cent of allowable weight and rounding down to the nearest hundred kilograms.”

A review of system records for weighbridges at Kapiri Mposhi, Kafue, and Livingstone revealed that 2119 transactions were recorded as overloaded on Gross Vehicle Mass (GVM) and axle or a combination of axles.

Table 15: Vehicles with All Axles not Recorded

No.	Station	Weighbridge	Type of Overload	No. of Transactions	Amount (K)	Schedule
1	Kapiri Mposhi	A	GVM	76	934,200	16a
			Axle	148	3,047,859	16b
			Sub-Total	224	3,982,059	
	Kapiri Mposhi	B	GVM	2	6,315	16c
			Axle	92	33,040	16d
			Sub-Total	94	39,355	
2	Kafue	A	GVM	312	3,259,741	16e
			Axle	631	998,871	16f
			Sub-Total	943	4,258,612	
3	Kafue	B	GVM	26	132,166	16g
			Axle	54	1,542,153	16h
			Sub-Total	80	1,674,319	
4	Linigstone		GVM	12	34,802	16i
			Axle	766	1,863,152	16j
			Sub-Total	778	1,897,954	
			Total	2119	11,852,299	

However, a comparison of the weighbridge transaction records with the corresponding cashbook showed that no payments were recorded for these 2119 overload transactions. This suggests that vehicles identified as overloaded were allowed to proceed without the required penalties or compensation being collected.

Risk

- Revenue Loss
- Accelerated Road Infrastructure Deterioration

Recommendation

Management should ensure that they implement/ strengthen system-integrated validation controls.

Management Response

ii. Revenue not traced on the Bank Statement

Regulation 8 (f) of Statutory Instrument No. 97 of 2020 stipulates that an accounting officer shall undertake a reconciliation of accounts held under that accounting officer's charge at least once in a month.

A review of the Revenue Summary (return) and the deposit slips at Livingstone weighbridge Station revealed that on 21st February 2025 and 17th May 2025, (\$20 and \$40 respectively), were collected and deposited in the Zanaco Dollar Transit Account No. 0393996300227. However, the two transactions could not be traced on the Zanaco Transit Account Bank Statement obtained from NRFA headquarters under the station bank code T1018. As a result, it could not be ascertained whether the revenue in amounts totalling \$60 was swept to the treasury during the year under review.

Risk

Theft of Government funds at the bank.

Recommendation

Management should ensure that bank reconciliations are conducted monthly by all the weighbridge stations, since they are the custodians of the source documents. Monthly bank statements can be obtained from NRFA HQ using the station bank codes.

Management Response

iii. Failure to file bank deposit slips in an orderly manner to facilitate their retrieval

Regulation 8 (f) of Statutory Instrument No. 97 of 2020 stipulates that, an accounting officer shall undertake a reconciliation of accounts held under that accounting officer's charge at least once in a month.

However, during the audit it was observed that the deposit slips for the two (2) Transit accounts held with Zanaco Bank used by Kafue weighbridge station (ZMW Account No 0393996300328 and US-Dollar Account No 0393996300227) were mixed in one box-file.

As a result, it was difficult to retrieve a single set of the deposit slips for reconciliation purposes.

Risk

Bank reconciliations may not be performed.

Recommendation

Management should ensure that the deposit slips for various bank accounts are kept separate for easy retrieval during bank reconciliations.

Management Response

n. Weaknesses in management of Information Systems

i. Business Continuity and Disaster Recovery Plan

During the period under review, it was observed that backups were being done at the toll stations, at NRFA HQ and at Infratel. An analysis of the processes revealed the following:

- **Lack of Offline Backup**

According to COBIT 2019 AP014.10 on Manage data backup and restore arrangements, an institution should define requirements for on-site and off-site storage of backup data that meet the business requirements.

A review of the backup arrangements at the NRFA revealed that the agency did not have an offline backup. Offline backups are critical because they provide an immutable copy of data, shielding it from ransomware, network-based cyberattacks, and malware that can corrupt online or cloud backups. They ensure data recovery during internet outages and hardware failures.

Lack of offline backup may lead to Backups being encrypted, deleted, or compromised during a ransomware or cyberattack ultimately leading to increased risk of permanent data loss.

In response, management indicated that they currently conduct regular off-site backups at Infratel and that they had commenced arrangements to implement an offline storage solution. However, this had not been implemented as of April 2026.

Risk

- Unauthorised access to backups.
- Loss of data if online backups are compromised.

Recommendation

Management should implement offline backup.

Management Response

- **Failure to Review Application and Firewall logs**

ISO/IEC 27001:2022 Annex A, Control 8.16 – Monitoring activities, stipulates that network, systems and applications shall be monitored for anomalous behaviour and appropriate actions taken to evaluate potential information security incidents.

However, an enquiry on the procedures put in place for reviewing the application logs and the firewall logs reviewed that there was no evidence that the Agency was monitoring and regularly reviewing the application logs and firewall logs.

Failure to review application and firewall logs may lead to security incidents or unauthorised activities going undetected and this increases exposure to cyber threats.

Risk

Failure to detect unauthorised access network resources and data.

Recommendation

Management should ensure that measures are put in place for regular reviews of the application and firewall logs.

Management Response

- **Failure to Plan for the Retirement of Unsupported Servers**

COBIT 2019 BAI09.03 manages the asset life cycle requires that the entity should manage assets from procurement to disposal ensuring that assets are utilised as effectively and efficiently as possible and are accounted for and physically protected until appropriately retired.

However, a physical inspection carried in the server room reviewed that NRFA was using fourteen (14) HP ProLiant Gen9 server which were using Windows server 2022 which had reached its end-of-life support on 22nd July 2025. This exposed the Agency to known vulnerabilities, inability to leverage current security features. This may weaken both the security and operational resilience of the ICT infrastructure.

Table 16: Unsupported servers

Services Running	End of life Support
Etoll app server	22nd July 2025
Etoll Secondary Database server	
File server 1	
VMWare Esxi 8 Host 1 for call Centre and VOIP Systems	
Mail Exchange Server	
Hyper-V Host server for biometric access control, antivirus server and primary domain controller	
In-house applications: leave, overtime etc	
Decommissioned old etoll system X3	
New payroll system	
Contract Management System (CMS) UAT.	
Contract Management System (CMS).	

Risk

Unauthorised access.

Recommendation

Management should ensure that plan for the replacement of the unsupported servers.

Management Response

ii. Weaknesses in the Management of Active Directory

- **Use of an Unsupported Operating System**

ISO/IEC 27001:2022 Annex A, Control 8.8 – Management of technical vulnerabilities, stipulates that information about technical vulnerabilities of information systems in use shall be obtained, the organisation's exposure to such vulnerabilities shall be evaluated, and appropriate measures shall be taken.

It was observed that the NRFA was using windows operating systems which had reached the end of support. **Schedule 19**

Continued use of an unsupported operating system increases the risk of data loss or compromise.

Risk

Unauthorised access.

Recommendation

Management should ensure that they upgrade the operating system.

Management Response

- **Failure to Lock Inactive Accounts**

ISO/IEC 27001:2022 Annex A, Control 5.18 – Access rights, stipulates that Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed in accordance with the organization's topic-specific policy on and rules for access control.

A review of the Active Directory revealed that eighty-seven (87) user accounts had never been accessed since their creation. This condition exposes the accounts to potential misuse or unauthorized access. **Schedule 20.**

Risk

Unauthorised access.

Recommendation

Management should ensure that the inactive accounts are locked.

Management Response

- **Failure to set Expiry Period for Passwords**

Section 11.1 (iii) of the NRFA Security Policy states that all user-level passwords such as email, web, desktop/laptop computer must be changed at least every 30 days.

A review of the active directory for the Agency revealed that there were seventy-eight (78) user accounts which were set never to expire. This exposed the Agency to unauthorised access in that if an account with a "never expires" password is compromised, an attacker can maintain access indefinitely without being forced to change the password. **Schedule 21.**

Risk

Unauthorised access.

Recommendation

Management should ensure that user accounts are set to expire.

Management Response

iii. Weaknesses in the Management of Network

The agency's network architecture comprises multiple toll stations operating on independent Local Area Networks (LANs), each configured as a separate subnet. These LANs are interconnected with the Head Office through a Multi-Protocol Label Switching (MPLS) based Wide Area Network (WAN), enabling secure and reliable communication between sites. Each toll station LAN is protected by its own standalone firewall that independently controls, monitors, and routes network traffic, without remote management from Head Office. Through the MPLS WAN, essential services

and data, including database files, email services, antivirus updates, and CCTV data, are shared between the Head Office and the toll stations, ensuring operational continuity while maintaining network segmentation and security. A review of the network configuration revealed the following;

- **Firewall**

- **Failure to Enable Service Password Encryption**

COBIT 2019 DSS05.04 Manage Network and Connectivity Security.
The network infrastructure shall be secured to protect against unauthorised access.

Service Password Encryption is a feature of Cisco IOS that obscures plaintext passwords within configurations through encryption. Cisco's best practice requires that service password encryption be enabled to ensure all passwords in configurations are encrypted.

A review of the configuration files revealed that service password encryption was not enabled on the routers. This oversight could allow malicious actors with access to the configuration files to easily obtain passwords in clear text, bypassing the need for decryption or brute-force attacks.

Risk

Unauthorised access.

Recommendation

Management should ensure that the security of the firewall is enhanced to address issues related service password encryption are addressed.

Management Response

- **Failure to Provide Warning Notification in the Pre-logon and Post-logon Banners**

ISO 27001:2022 Annex A Control 5.10 (Acceptable use of information and other associated assets) requires users to be made aware of and comply with acceptable use rules. Additionally, Annex A Control 5.18 (Access rights) deals with ensuring users understand their responsibilities when accessing systems. A Pre-Logon and Post-Logon Banner's Message is a notification or warning displayed to users after they have successfully logged into a system, application, or network. These banners are often used for informing users of acceptable use policies, privacy laws, or monitoring disclosures.

Best practice recommends the provision of a warning notification in the banner to warn intruders to the network's resources. From a security point of view, a login banner should not contain any specific information about the network device name, model, software, or ownership. This information can be abused by malicious users.

No pre-logon or post-logon warning notification banners were configured on the routers to warn and deter unauthorised users from accessing network devices. In the absence of explicit legal notification, evidence of unauthorised access may be challenged in legal proceedings, potentially compromising the Agency's ability to pursue prosecution or disciplinary action.

Risk

Failure to take legal action against offenders.

Recommendation

Management should consider configuring pre-logon or post-logon warning notification banners.

Management Response

- **Core Switch**
- **Interfaces Configured with No Filtering**

ISO/IEC 27001:2022 control A.8.20 (Network Security) requires that networks and network services be secured, and A.8.21 (Security of Network Services) mandates the implementation of appropriate security mechanisms for network services. Best practices require that network devices be configured with Access Control Lists (ACLs) to filter network traffic and prevent unauthorised access to hosts and services.

It was observed that forty-four (44) interfaces for the CORE-NRFA_HQ-01 device were configured without either inbound or outbound network filtering. These are listed below;

Table 17: Interfaces Configured with no Filtering

No.	Interface Name	No of Interfaces	Schedule
1	Port channel interfaces were not configured to filter network traffic	3	22(a)
2	Gigabit Ethernet interfaces were not configured to filter network traffic	25	22(b)
3	Other interfaces were not configured to filter network traffic	4	22(c)
4	VLAN interfaces were not configured to filter network traffic	12	22(d)

Without ACLs, the core switch cannot prevent unauthorised lateral movement between network segments, exposing critical assets to unnecessary risk and compromising the defence-in-depth architecture required by the information security management system.

Risk

Unauthorised access.

Recommendation

Management should ensure that they enhance controls on inbound and outbound network filtering.

Management Response

- **Failure to Disable HTTP Service Connections**

ISO 27001:2022 Annex A Control 8.22 on segregation of network requires that groups of information services, users and information systems be segregated in the organisation's network.

Hypertext Transfer Protocol (HTTP) is used to access the router through a web browser. However, Cisco best practice recommends disabling the HTTP service or using a secure, encrypted remote management method such as Secure Shell (SSH) or Hypertext Transfer Protocol Secure (HTTPS) to prevent unauthorised access.

A review of the configuration file of the CORE-NRFA_HQ-01 revealed that the HTTP server was enabled. The continued operation of unencrypted HTTP administrative services exposes the Agency to administrative credentials transmitted via HTTP, which are susceptible to interception through passive network sniffing or man-in-the-middle (MitM) attacks, potentially granting attackers privileged access to core network routing infrastructure.

Risk

Unauthorised access.

Recommendation

Management should ensure that they disable HTTP service connections.

Management Response

- **Inadequate Access Control Implementation on CORE NRFA HQ 01**

ISO/IEC 27001:2022 Annex A Control 8.20 (Network Security) requires organisations to ensure that networks and network devices are appropriately secured, managed, and controlled to protect information within systems and applications.

The Cisco router CORE NRFA_HQ 01 was found to lack Access Control Lists (ACLs) for both network traffic filtering and administrative access. This condition exposed the device and the NRFA network to potential unauthorised access from untrusted sources.

○ **Unrestricted Network Traffic Flow (Data Plane)**

The router had no ACLs configured to regulate inbound or outbound network traffic. As a result, unrestricted traffic was permitted between any source and destination addresses and services. This configuration is contrary to security best practice, which requires network access to be limited strictly to authorised hosts and services. The absence of traffic filtering increases the risk of unauthorised access to NRFA network services and potential compromise or loss of sensitive information.

○ **Unrestricted Administrative Access (Control Plane)**

Remote administrative services (Telnet and SSH) configured on VTY lines 0–4 and 5–15 were not protected by ACLs restricting which hosts or networks could initiate management sessions. In the absence of such restrictions, any external host could attempt to access the router's management interface. Should authentication credentials be compromised or bypassed, this could result in full administrative control of the device.

Risk:

Unauthorised access to network services and administrative control of critical network infrastructure, potentially leading to data loss, service disruption, and compromise of the overall network environment.

Recommendation:

- Management should implement ACLs to restrict network traffic to only authorised hosts, networks, and services.

- Management should apply host-based ACL restrictions on all VTY lines (0–4 and 5–15) to permit administrative access only from trusted management hosts or networks

- **Failure to Enable Post-Logon Banner Message**

ISO 27001:2022 Annex A Control 5.10 (Acceptable use of information and other associated assets) requires users to be made aware of and comply with acceptable use rules. Additionally, Annex A Control 5.18 (Access rights) deals with ensuring users understand their responsibilities when accessing systems. A Post-Logon Banner Message is a notification or warning displayed to users after they have successfully logged into a system, application, or network. These banners are often used for informing users of acceptable use policies, privacy laws, or monitoring disclosures.

A review of the router's configuration files revealed that the Post Logon banner was not configured on the following routers. This omission violated these controls, as the absence of a post-logon banner meant authenticated users were not formally reminded of their obligations regarding privacy laws, monitoring disclosures, or acceptable use policies.

Risk

Failure to take legal action against offenders.

Recommendation

Management should ensure that they configure post-logon warning notification banners.

Management Response

- **Unrestricted VLAN Trunking Enabled on Switch Ports**

ISO 27001:2022 Annex A Control 8.22 on segregation of network requires that groups of information services, users and information systems be segregated in the organisation's network.

Switch Port Trunking is a networking feature that allows a single physical network connection to carry traffic for multiple Virtual Local Area Networks (VLANs) simultaneously. Cisco devices default to allowing trunk negotiation if the connected device supports a common trunking protocol, which can result in unintended trunk establishment.

A review of the router's configuration files revealed that twelve (12) interfaces were configured with VLAN trunking enabled. This exposed the Agency to unauthorised access in that an attacker could gain unauthorised access to multiple network segments if they can establish a trunk connection. **Schedule 24.**

Risk

Unauthorised access.

Recommendation

Management should ensure that they enhance controls to restrict unauthorised access to the network.

Management Response

- **Use of Insecure Clear Text Secure Simple Network Management Protocol (SNMP)**

Simple Network Management Protocol (SNMP) allows management and monitoring of networked devices by providing a wealth of information on the status of the network.

Best practice in network security recommends that SNMP be properly secured, such as use of SNMP version 3, in order to protect the confidentiality, integrity, and availability of both the network data and the network devices through which data transits.

SNMP versions 1 and 2c are known as clear-text protocol services. They provide no encryption for either the authentication or the data sent between the

SNMP agent and the Network Management System (NMS) or SNMP management hosts.

NRFA's CORE-NRFA_HQ-01 was configured to use clear-text SNMP, which was not secure against unauthorised access by intruders. This rendered the network susceptible to unauthorised access.

Risk

Unauthorised access.

Recommendation

Management should ensure that a more secure protocol is implemented to manage network communication.

Management Response

iv. ICT Weaknesses at Toll Stations

- **Failure to Capture Transaction Images**

Part 5 of Addendum I to the contract between the National Road Fund Agency and NECOR Zambia Limited for the procurement of the NECOR Tolling System (intended to replace the AVIC and EFKON systems) requires that the system captures and stores images of vehicles at the time of transaction to enable correlation between vehicle passage and recorded revenue.

However, a review of system transactions revealed that thirty-three (33) vehicles that passed through seven (7) toll stations did not have corresponding images recorded in the system. See table below.

Table 18: Failure to Capture Transaction Images

No.	Station	No of Vehicles	Schedule
1	Sabina	4	25 a
2	Wilson Mofya Chakulya	7	25 b
3	Micheal Chilufya Sata	3	25 c
4	Enock Kavindele	8	25 d
5	Kateshi	3	25 e
6	Kakonde	4	25 f
7	Kalense	4	25 g
	Total	33	

Risk

Inability to prosecute violations.

Recommendation

Management should ensure that they implement real time camera maintenance.

Management Response

- **Lack of Server Room-Kakonde Toll Station**

ISO/IEC 27001:2022 Control A.7.1 (Physical Security Perimeter) requires the establishment of secure areas.

An inspection of the servers at Kakonde Toll Station revealed there was no server room at the station in that the office where other furniture and stationery is kept that is where the server is located. This exposed critical infrastructure to physical attack, information leakage and increased the risk of natural light exposure and other environmental hazards.

Although Management in response indicated that the upgrade is underway, no documentary evidence had been provided for audit. Further no compensating controls had been implemented in interim while awaiting for the upgraded to be done.

Risk

Loss of information and equipment.

Recommendation

Management should ensure that the servers are stored in a secure and conducive environment.

Management Response

- **Shared User Accounts**

ISO/IEC 27001:2022, Annex A 5.16 on Identity Management, requires the full lifecycle management of identities and enforces the "one user, one ID" principle to ensure individual accountability. It requires that an identity assigned to a person is used exclusively by that person, preventing the use of shared accounts.

A review of the MySQL database server at the Michael Chilufya Sata revealed that administrators are sharing a generic user account, as no evidence of personalised administrator accounts was found.

Risk

The use of shared accounts prevents the organisation from establishing individual accountability, making it impossible to attribute specific actions or changes to a specific administrator.

Recommendation

Management should ensure that personalised user accounts are provisioned for all administrators and that shared administrative accounts (where actions cannot be attributed) are disabled or strictly prohibited for routine access.

Management Response

- **Non-Functional Air Conditioner in the Sever Room**

COBIT 2019 DSS01.04 on managing environment requires institutions to regularly monitor and maintain devices that proactively detect environmental threats (e.g., fire, water, smoke, humidity).

However, it was observed that the server rooms at Wilson Mofya Chakulya and Nalumino Mundia Toll Stations each had only one air conditioning unit, which was not operational. These server rooms house critical IT infrastructure, including servers and network equipment that support toll collection operations.

The absence of adequate environmental controls exposes the equipment to a heightened risk of overheating, which may result in hardware failure, system downtime, potential data loss, and disruption of revenue collection activities.

Risk

- Overheating of servers and network devices, leading to hardware damage or failure.
- Potential interruption of toll collection operations resulting in revenue loss.

Recommendation

Management should ensure that the air-conditioning unit in the server room is repaired or replaced immediately to restore adequate environmental controls.

Preventive maintenance schedules should also be implemented to minimize future failures and ensure continuous protection of critical IT infrastructure.

Management Response

- **Server Not Secured in Server Rack**

ISO 27001 Control A.7.1 Control A.7.1 (Physical security perimeter) requires secure areas to be protected by appropriate entry controls, and Control A.7.8 (Equipment siting and protection) mandates that equipment be sited or protected to reduce risks from environmental threats and unauthorised access.

A physical inspections of server rooms at Michael Chilufya Sata and Kebby Musokotwane revealed weaknesses in the physical security of critical IT infrastructure. At Michael Chilufya Sata, key server equipment was observed to be placed outside secured server racks, rendering it physically exposed and vulnerable. Similarly, at Kebby Musokotwane, the server rack housing critical equipment was not adequately secured, with the side panel removed and the rack door left unlocked, thereby exposing the equipment to potential unauthorized access and physical damage.

Risk

Unsecured servers are vulnerable to accidental damage from personnel traffic, environmental contamination (dust, spills), among others.

Recommendation

Management should ensure that the server is relocated to lockable, access-controlled server racks with adequate ventilation and cable management.

Management Response

- **Cables Not Properly Secured in Trunking**

ISO/IEC 27001:2022 Control A.7.12 (Cabling Security) requires that power and telecommunications cabling be protected from interception, interference, or physical damage. This includes ensuring that cabling is routed through secure pathways such as conduits or trunking and adequately protected to prevent accidental or deliberate harm.

An inspection of the server room revealed that critical communication cables at the Chongwe, Nalumino Mundia, and Kebby Musokotwane Toll Stations were not properly secured within the trunking, resulting in exposed sections of cabling that were insufficiently protected. This condition increases the risk of physical damage and potential interference.

Risk

- Damage to cables which might lead to network failure.
- Disruption to toll collection operations.

Recommendation

Management should ensure that all communication and power cables are properly secured within trunking and other protective conduits to prevent exposure and reduce the risk of physical damage or interference.

Management Response

- **Earthing Not Properly Secured/Clamped/Not Secured**

ISO 27001 Control A.7.1 (Physical security perimeter), which encompasses proper electrical supply and cabling protection.

An inspection of the server room revealed that there were no electrical earthing connections of the electronic equipment and the server rack to the Common Bonding Network (CBN) in the server rooms for Michael Chilufya Sata, Shimabala, and Chongwe, presenting potential safety and equipment protection deficiencies.

Risk(s):

Inadequate earthing poses significant risks, such as electrical surges or lightning strikes, which can damage expensive server equipment due to ineffective grounding.

Recommendation(s)

Management should ensure that all server room equipment and server racks at Michael Chilufya Sata, Shimabala, and Chongwe are properly earthed and connected to the Common Bonding Network (CBN) in line with applicable electrical and safety standards.

Management Response

- **Inconsistent Data Backup**

Section 12.2 (i) and (ii) of the ICT Disaster Recovery and Business Continuity Plan requires that the responsible ICT Technician at each station ensures that automated database backups are configured to run daily, copying the database to Local Drive D at the end of each day. Further, the ICT Technician is required to copy the database from Local Drive D to an external Hard Disk Drive (HDD) and transmit it to the Head Office file server for automated off-site backup.

However, a review of backup procedures at Enock Kavindele Toll Station revealed non-compliance with these requirements. Automated database backups were not configured, and manual backups, where performed, were inconsistent, with instances noted where no backups were conducted on certain days.

Risk

Incomplete information for decision making.

Recommendation

Management should ensure that there is consistency in data backup.

Management Response

- **Toll Lane Display Screens Not Working at Stations**

Part 19 of the Addendum I to the contract between National Road Fund and NECOR Zambia Limited for the procurement of the Necor Tolling System to replace Avic and EFKON System states that each lane should be mounted with an electronic display board, and the system should display information. The information to be displayed includes, but is not limited to, vehicle registration number, amount due, and sensitisation messages

Functional toll lane display screens represent established best practice in intelligent transportation systems (ITS) and electronic toll collection (ETC) operations.

A physical inspection of tolling booths revealed that display screens intended for motorist confirmation of vehicle registration numbers and toll fees were non-functional at the following Toll Stations, namely Micheal Chilufya Sata, Kateshi, Shimabala, Mumbwa, Nalumino Mundia, Kebby Musokotwane, Daniel Munkombwe and Chongwe.

These screens fail to present critical transaction information to motorists during the toll collection process, forcing reliance on verbal communication or a complete absence of verification.

Risk

This increases the likelihood of incorrect toll application, deliberate under-declaration by motorists, or operator error resulting in potential revenue leakage.

Recommendation

Management should ensure that they repair or replace all Non-Functional Display Screens

Management Response

- **Incomplete Three-Tier Power Configuration – Absence of Solar Power Backup**

ISO 27001:2022 Control A.8.13 (Information Backup) and Control A.8.14 (Redundancy of Information Processing Facilities) require that information processing facilities have sufficient redundancy to meet availability requirements. Additionally, Control A.8.11 (Uninterruptible Power Supplies) mandates the use of UPS and backup power systems to ensure the availability of information processing facilities during power failures.

A review of the Station's power infrastructure at Nalumino Mundia Toll Station revealed that it is incomplete, operating on only two of the three required power sources: grid power and a generator (Genset). During grid power outages, there is

a brief gap before the generator is manually switched on and comes online, during which the Toll Booth systems receive no power.

Risk

The absence of a third-tier power source (such as solar power) increases the risk of system downtime, transaction loss, equipment damage, and non-compliance with ISO 27001 availability requirements.

Recommendation

Management should implement a complete three-tier power configuration by installing a solar power backup solution to ensure continuous system availability and eliminate unprotected power transition periods.

Management Response

- **Lack of Centrally Managed Antivirus System**

ISO/IEC 27001:2022, Annex A 8.7 – Protection against malware shall be implemented and supported by appropriate user awareness. This control specifically addresses the need for protective, detective, and corrective measures against malware (including viruses, ransomware, and spyware) across all organisational endpoints.

It was observed that antivirus software across the toll stations was not centrally managed. A review of computers and servers at Michael Chilufya Sata, Shimabala, Mumbwa, Nalumino Mundia, Lui, Kebby Musokotwane, Daniel Munkombwe, and Chongwe Toll Stations revealed that antivirus solutions were deployed as stand-alone installations on individual machines.

This decentralised approach limits the ability of IT administrators to enforce consistent security configurations, centrally monitor threats in real time, uniformly deploy critical virus definition updates, and respond promptly to malware incidents. Consequently, the absence of centralised visibility increases the risk that compromised systems may remain undetected for extended periods, thereby allowing threats to propagate laterally across the network.

Risk

The absence of centralised antivirus management exposes the organisation to elevated cybersecurity risks.

Recommendation

Management should implement a centrally administered antivirus/endpoint protection solution to ensure standardised security settings, automated updates, and enhanced monitoring across all Toll Station systems.

Management Response

8. Appreciation

I would like to take this opportunity to express my gratitude for the courtesy extended and assistance rendered by you and your staff to the audit team.

9. Inquiry

I would appreciate to receive your comments and explanations you may have concerning the issues raised in this management letter not later than fifteen (15) days from the date of receipt of this report.



Dr. Ron M. Mwambwa, FCMA, FZICA, CGMA, CFE
ACTING AUDITOR GENERAL

cc: The Permanent Secretary – Planning and Administration
Ministry of Finance and National Planning
P.O. Box 50062
LUSAKA